

Staff Guidelines

Information Security



Resilience System Design and Alignment to Standards

This resilience system has been designed by Risk and Strategic Management, Corp (RSM), a specialist company expert in designing and implementing complex resilience strategies which protect people, facilities, assets, information, operations and organizational reputation. This system has been aligned to the following ISO and BSI standards to ensure it reflects the professional standards and practices of High Reliability Organizations: ISO 31000: Risk management; ISO 22317: Business impact analysis; ISO 22301: Business continuity management; ISO 22320: Emergency management; ISO 34001: Security and resiliency; ISO 22316: Organizational resiliency; and BSI 17091: Crisis management.

Why is Information Security Important

Effective information security ensures that no data is lost, stolen, or left unsecured – regardless of the sensitivity of the data. Any information that may cause harm or embarrassment to individuals, the organization, or external stakeholders by criminals, hostile governments, the media, militants, or terrorists should be considered sensitive and should be appropriately protected.

Specific examples of sensitive information include the following:

- Contract and financial information
- Operational plans and reports
- Organizational strategies
- External stakeholder information
- Business proposals
- VIP visits and activities
- Intellectual property
- Travel records and schedules
- Staff biodata and Next of Kin records
- Promotional and discipline reports
- Crisis and incident policies or reports
- Insurance documents
- Compensation packages
- Client meetings and events
- Investigations
- Security policies and plans

The risks from poor information security include:

- Theft, robberies, mugging and burglaries
- Assaults resulting in injuries or death
- Kidnapping and hostage taking
- Armed attacks
- Negative media attention
- Loss of competitive advantage and business
- Individual or organization embarrassment
- Legal and reputational risks
- Damages to employee morale
- Harm to external stakeholders

Your Responsibilities...

Sound information security practices can significantly reduce the potential for our organization to be targeted by hostile individuals and groups, protecting people, information, operations, and our business interests. Failure to obey these measures will inevitably result in a breach of security. Information security includes:

- Limiting access to your data, using layers of encryption and security protocols
- Securing physical data storage assets or hard copy information
- Reducing vulnerabilities which might enable data loss of theft
- Reporting breaches of security immediately
- Being aware of your surroundings and where others can overhear your conversations

Data Security Protocols

The following are some of the areas where you are responsible for information security:

1. **Clear Desk Policy:** Sensitive information should be locked away when not in use, especially overnight when cleaners may have unrestricted access to the facility. Personnel using sensitive data should be provided lockable cabinets or rooms where data can be secured.
2. **Traveling with Data:** Travelers should consider what information they require for the trip and whether the loss of any information may compromise individuals, the organization or other stakeholders. If the potential for loss or theft is high then individuals may need to request a sanitized laptop. Only essential information should be carried – typically on an encrypted a flash drive or external hard drive.
3. **Data Theft:** If persons lose data or have assets stolen then they should immediately report the incident to a manager and provide a full list of information stolen so that a Risk Assessment can be conducted on the potential implications of the loss. Any affected parties, including external stakeholders, office recipients, partners, implementers, and subcontractors may need to be notified by an appropriate manager. Police and or government agencies might also need to be informed. The same considerations are applied if data is believed to have been compromised.

4. **Erasing Data:** The Information Technology department is responsible for the disposal when disposing of computers, hard drives, flash drives, and network equipment.

5. **Disposing of Hard Data:** Hard data files, paper and documents should be destroyed in a manner which protects the integrity of the information. This may be achieved through a shredder, or, in the absence of a shredder, the documents may be burned.

6. **Passwords:** Create long passwords (minimum of 8 characters) with numbers, mixed-case characters, and special symbols. A good example of a password would be: *!lOveMyMutæ5934*. A bad example would be: *JohnDoe*. **DO NOT** use any passwords that can be tied to who you are – such as passwords that include your social security number (SSN), your birthday, your children’s names, or your spouse’s middle name. Instead, create a random password with numbers, letters, symbols (if allowed), and both capitalized and uncapitalized letters. Try to create a password that you can remember without having to write it down but still is as random as you can make it. If you need to write down a password, carry it in a secure place like your wallet. **DO NOT** carry your password with your computer.

7. **Virus/spyware/tracking cookies:** When accessing the internet, especially if downloading off of an open server, then you will accumulate spyware and tracking cookies. These can be removed with a spyware/tracking cookie remover. Viruses, worms, and Trojans are more difficult to remove. They can generally be avoided by:
 - **DO NOT** open attachments or links in an email unless you can verify whom it is coming from.
 - **DO NOT** turn off your firewall. Set the security level to its highest level.
 - **DO NOT** disable your pop-up browser.
 - **DO NOT** download torrents, files, or from peer-to-peer locations. Contact the Information Technology Department if you suspect a site is fraudulent.
 - **DO NOT** leave passwords laying around, your computer unlocked, or unwatched in a public space.
 - **DO NOT** give away personal or organizational information to anyone who you do not know and trust. If possible, verify their identity with a trusted third-party before communicating with unknown persons.

Data Theft: Take extra care of your computer when travelling to public and/or dangerous areas. Dangerous can be defined as any place where your sensitive material or hardware is in danger of being stolen, broken, or tampered with.

- Always keep your computer in a secure location. If possible, lock up your computer to prevent theft. If staying in a hotel room with a room safe then use this to store your computer and all sensitive materials if you leave the room unoccupied.
- Store all computer files in shared system folder to ensure it gets backed-up whenever you connect to the Internet.
- If you need to leave a laptop in a vehicle then secure this in the trunk / boot, not within the main body of the vehicle which might attract criminal attention.

Individual Security Management Protocols

Protecting information can relate to what you say and do when travelling, socializing, or working. Being situationally aware of your surroundings and what you and others are saying and doing is very important. Some important information security rules include:

- **Photos and Videos:** Do not take and transmit photographs or videos of sensitive areas, people, or activities, unless you have been authorized to do so. This can provide compromising information which can be used to present a threat to people, assets, and operations. It can also cause significant embarrassment, especially if shared with the media. If you are permitted to take photos and videos you are not to share these until an activity is completed.
- **Emails and Texting:** Assume emails and texts that are transmitted outside of the organization are not secure. These can be easily intercepted by hostile groups or may be shared with a much wider group which the sender did not anticipate.
- **Social Media:** You should not post organization related images, information, or comments on any form of social media without approval – these are open mediums for public information sharing and will quickly be shared with a much wider group than you intend. Never post sensitive information of an activity before it occurs – this will provide hostile individuals and group's time to plan and implement their goals as you have provided them the necessary information to accomplish this. You should assume anyone can access your social media information.

- **Conversations and Phone Calls:** You must always be aware of your surroundings and assume that others may be listening to your conversations or phone calls. Often people forget who may be nearby and how far sound travels, resulting in you or others unknowingly divulging sensitive information. You should find a secluded or private area to hold discussions or phone calls. You should also understand that some areas may be bugged with electronic eaves dropping devices, such as conference areas and hotel rooms.
- **Sharing with Friends and Family:** You should understand that while you can trust your family and friends, people do tend to gossip and there is a real danger that they may tell someone about your activities without intending harm. They may also send emails, share photographs or documents, or be overheard themselves, compromising you and others. As such, you should be selective with what you share and caution them about information security measures.
- **Reading Reports and Documents:** Often people want to read documents or reports on their laptops or paper copies when travelling. Often, they are unaware that others may be able to read the information, especially when on flights or in trains where people are in proximity. Care should be taken to ensure that people cannot read information “over your shoulder”. Protective screens can be used on laptops to reduce this risk.

Other Instructions